

Vulnerability Assessment Report

Scenario

You are a newly hired cybersecurity analyst for an e-commerce company. The company stores information on a remote database server since many of the employees work remotely from locations all around the world. Employees of the company regularly query, or request, data from the server to find potential customers. The database has been open to the public since the company's launch three years ago. As a cybersecurity professional, you recognize that keeping the database server open to the public is a serious vulnerability.

You are tasked with completing a vulnerability assessment of the situation to communicate the potential risks to decision-makers at the company. You must create a written report that explains how the vulnerable server is a risk to business operations and how it can be secured.

System Description

The company's remote database server is a key system used to store customer data, campaign records, and marketing analytics. It runs on a Linux operating system with MySQL for database management. The server hardware includes a high-performance CPU and 128GB of RAM. It uses IPv4 networking and supports encrypted communications via SSL/TLS.

This server is accessed frequently by employees working remotely across the globe. Since the company's launch three years ago, the server has been left publicly accessible, without strong access controls. While convenient, this poses a major security risk.

Scope

This vulnerability assessment focuses on the access control policies and exposure risks related to the database server, with special attention to remote access over the internet. The analysis uses the NIST SP 800-30 Rev. 1 framework.

Purpose

The database supports key marketing and business operations by storing customer and analytical data. Keeping this system secure is essential because:

A data breach can lead to loss of customer trust.

Tampering with data can affect marketing campaigns and business decisions.

Regulatory fines may result from non-compliance with data protection laws (e.g., GDPR).

Risk Assessment

Threat Source | Threat Event | Likelihood (1–3) | Severity (1–3) | Risk Score

Hacker | Exfiltration of sensitive data | 3 (High) | 3 (High) | 9

Employee | Accidental disruption of operations | 2 (Moderate) | 2 (Moderate) | 4

Customer | Unintended alteration or deletion of data | 1 (Low) | 2 (Moderate) | 2

Threat source	Threat event	Likelihood	Severity	Risk
Hacker	Exfiltration of sensitive data	3	3	9
Employee	Accidental disruption of operations	2	2	4
Customer	Unintended alteration or deletion of data	1	2	2

Highest Risk: The server being publicly accessible allows hackers to attempt unauthorized access, data exfiltration, or surveillance. This can cause serious damage to company operations and reputation.

Approach

This assessment uses the NIST methodology to identify and evaluate risks. We considered:

- The ease of accessing the system without authentication.
- The type of data stored.
- The impact of a potential attack or data breach.

Remediation Strategy

To reduce the risk and secure the server, I recommend the following immediate steps:

Access Controls:

- Implement role-based access control (RBAC) so only specific employees can access the server.
- Require strong, complex passwords and enforce password expiration policies.

Authentication:

- Set up multi-factor authentication (MFA) for all users connecting to the server remotely.
- Replace SSL with more secure TLS v1.2 or higher for encrypted communication.

Authorization & Auditing:

- Create logs for every user login and query to the server.
- Regularly review logs for suspicious activity.

IP Allow-listing:

- Restrict server access by setting up an IP allowlist—only allow traffic from known office IPs or trusted VPNs.

Firewall & Network Segmentation:

- Place the server behind a firewall and remove it from the public internet.
- Consider setting up a Virtual Private Network (VPN) for employees to connect securely.

Conclusion

Leaving a sensitive database server open to the public for three years creates a high-risk situation that could result in data theft or disruption of business operations. Using NIST SP 800-30 Rev. 1 as a guide, this report shows that the risk is serious and needs immediate attention. Implementing better access controls and network protections will greatly improve our cybersecurity posture.